

Threat Assessment and Remediation Analysis

The Threat Assessment and Remediation Analysis (TARA) is a structured, risk-based methodology used to identify, prioritize, and mitigate vulnerabilities and threats to a specific system or organization.

In the context of this architecture review, the TARA framework is specifically being used to:

- **Identify Critical Vectors:** Pinpointing exactly how an attacker could breach the environment (e.g., compromising a public-facing Windows VM in Azure).
- **Map Lateral Movement Paths:** Analyzing the engineering mechanisms an attacker would use to pivot from that cloud beachhead into the on-premises network via the ExpressRoute.
- **Define Deficiencies:** Isolating what standard out-of-the-box compliance standards (like standard CIS Benchmarks) miss regarding multi-vector attacks.
- **Enforce Tool-Driven Remediation:** Creating deterministic, automated workflows between Snyk, SentinelOne, Cisco SASE, BeyondTrust, and Tines to systematically block or isolate those identified threat paths before execution.

This methodology has been updated to serve as an **Internal Architecture Review**. It formally maps the tool-enforced security policies to **NIST SP 800-53 Rev. 5** and **ISO/IEC 27005:2022** risk management guidelines.

The organization relies on limited leveraged Azure services; thus the primary threat vector is a compromised Windows VM being used to move laterally between Azure and the on-premises environment.

Tool-Specific TARA Gaps & Custom Configuration Checks

The matrix below outlines the critical threat vectors to address, identifying specific gaps left by CIS Benchmarks and providing the exact configuration steps required for the stack.

Security Tool Architecture Review & TARA Verification Framework

This framework provides an exhaustive, tool-by-tool baseline revision of the existing TARA plan. It expands standard CIS compliance gaps into deterministic configuration policies to address the primary threat vector: a compromised Azure Windows VM moving laterally to on-premises environments via ExpressRoute.

Tool-Specific Evaluation, Gap Matrix, & Framework Mapping

(Configured for FIPS 199 High-Impact Baseline)

Threat Vector / Domain	What CIS Benchmarks Overlook	How to Enforce Using the Tool Stack	NIST SP 800-53r5 / ISO 27005 Control Mapping
Privileged Access & Pivot Control	Focuses heavily on local account names, password complexity, and static auditing policies.	BeyondTrust + SentinelOne: Force all local administrative sessions to broker through BeyondTrust PRA with mandatory session recording. Trigger critical SentinelOne alerts if a local cmd.exe or PowerShell.exe process spawns with elevated privileges without a valid, concurrent BeyondTrust session token mapping.	NIST: AC-2, AC-3, AC-6 (High), IA-2 (1) (MFA) ISO: A.5.15, A.8.19, A.8.24
Pipeline-to-IaaS Vulnerabilities	Focuses exclusively on post-deployment OS-level configurations and Windows update patching schedules.	Snyk + Rapid7 / Tenable.io: Snyk must programmatically parse HashiCorp Terraform (.tf) templates in the CI/CD pipeline to block unapproved NSGs before provisioning. Post-deployment, Tenable.io/Rapid7 must execute authenticated scanning to isolate vulnerable open-source dependencies hidden within compiled third-party proprietary software binaries using the unique 128-bit Azure Virtual Machine Unique ID (vmId).	NIST: CM-3 (Configuration Change Control), SA-8, RA-5 (High) ISO: A.8.25, A.8.28, A.8.8

SASE / Egress Traffic Deviations	Assumes network layers and firewall rules remain entirely static and correct over time.	Cisco SASE + SentinelOne: Enforce rigid DNS configurations blocking custom or alternate routing tables within the guest OS. Cisco SASE must intercept and drop all outbound connections originating from Azure VMs that bypass the Secure Web Gateway (SWG). Cross-reference real-time traffic drops against SentinelOne network isolation telemetry.	NIST: SC-7, SC-7 (7) (Split Tunneling), SI-4 (High) ISO: A.8.20, A.8.22, A.8.16
Automated Incident Isolation	Minimizes remediation to isolated local event log generation and standard SIEM aggregation.	Tines SOAR: Orchestrate active API-driven validation loops. Upon a SentinelOne signal indicating credential dumping (e.g., unexpected lsass.exe handle requests), Tines must programmatically rewrite Azure NSG rule priorities to completely sever the compromised instance's access to the on-premises ExpressRoute circuit.	NIST: IR-4, IR-4 (1) (Automation), IR-6 (High) ISO: A.5.24, A.5.26, A.5.28
Financial Engineering Phishing Paths	Targets standard Outlook, Office, and local macro/trust configurations natively.	KnowBe4 + Tines: Deploy adaptive simulations focused on quantitative and financial analyst targets. If a user fails an advanced KnowBe4 "vishing" or spear-phishing drill, Tines must call BeyondTrust APIs to immediately degrade their local administrative permissions onto critical corporate resources.	NIST: AT-2, AT-3 (Role-Based Training), AC-6 (High) ISO: A.6.3, A.5.18

2. Implement the Tool-Enforced TARA Plan & NIST/ISO Alignment

[1. Snyc/IaC Guardrails] → [2. SASE & SentinelOne Edge] → [3. BeyondTrust Tiering] → [4. Tines Loop Validation]

Step 1: Establish Infrastructure-as-Code (IaC) Guardrails

- **Engineering Check:** Audit code-driven deployment flows for Windows infrastructure.
- **High-Impact Alignment (NIST CM-3, ISO A.8.25):** Snyc programmatically inspects Terraform code artifacts within active pipeline runners. It blocks builds that expose the Azure Serial Console or allow unprivileged application contexts to access the local Instance Metadata Service (IMDSv2), mitigating supply chain entry points before provisioning.

Step 2: Correlate Network Perimeters with Endpoint Activity

- **Engineering Check:** Continuously analyze hybrid egress routing paths across the environment.
- **High-Impact Alignment (NIST SI-4, SC-7, ISO A.8.16):** Cisco SASE blocks production databases from calling untrusted public IP space. If an unauthorized egress attempt trips a firewall rule, SentinelOne instantly initiates a differential memory capture of the guest OS. This payload streams into a highly restricted, private-endpoint-attached Azure Blob Storage container utilizing Customer-Managed Keys (CMK), satisfying forensic chain-of-custody objectives.

Step 3: Enforce Rigid Privileged Access Tiering

- **Engineering Check:** Validate administrative separation between public cloud assets and traditional on-premises infrastructure.
- **High-Impact Alignment (NIST AC-6, IA-2 (1), ISO A.8.19):** Funnel all administrative sessions exclusively through BeyondTrust PRA. Explicitly deny the reuse of local domain administrative credentials across Azure-hosted IaaS assets and local hardware estates. Breaking this credential continuity systematically neutralizes lateral propagation across the ExpressRoute boundary.

Step 4: Validate Automated SOAR Workflows

- **Engineering Check:** Verify that automated integration layers execute predictably without manual human intervention.
 - **High-Impact Alignment (NIST IR-4 (1), ISO A.5.26):** Tines triggers simulated alert telemetry injections at regular intervals. When Tenable.io or Rapid7 flags a critical unpatched vulnerability (CVSS ≥ 9.0) on a public transaction system, Tines automatically signals Cisco SASE to isolate the server into a micro-segmented quarantine zone until a clean vulnerability scan confirms successful remediation.
-

3. Critical Gaps & Risk Contextualization (ISO 27005 Framework)

Per the ISO 27005:2022 assessment workflow, the multi-vendor tool architecture introduces inherent secondary operational risks that must be continuously evaluated:

- **Tool Telemetry Desynchronization (Risk ID: R-01):**
 - **Consequence:** Divergence between Tenable.io and Rapid7 asset tracking creates critical visibility blind spots.
 - **Controls (NIST RA-5, ISO A.8.8):** The Tines SOAR data aggregation engine must treat the immutable Azure Virtual Machine Unique ID (vmId) as its universal primary key. Telemetry fields from both vendor agents must normalize to this single token, preventing an active Windows VM from dropping off the active scanning radar during volatile DHCP reassignments.
 - **Credential Exposure via Endpoint Agents (Risk ID: R-02):**
 - **Consequence:** High-privilege execution environments required for SentinelOne, BeyondTrust, and Cisco SASE (NT AUTHORITY\SYSTEM) can inadvertently expose secrets in raw log directories if improperly hardened.
 - **Controls (NIST IA-5, ISO A.8.20):** Enforce local access control lists (ACLs) that strictly restrict agent data folders. Establish explicit logging rules to guarantee that debugging modes, local trace output files, and process memory logs never capture or store API keys, tenant organization tokens, or temporary infrastructure passwords in unencrypted plain text.
-

4. Technical Integration & Value-Binding Parameters

Target Azure Entra ID Object IDs

- **DFIR Analysis Security Group Object ID: 11111111-2222-3333-4444-555555555555**
 - ***Assigned Role:*** Storage Blob Data Reader (Scope restricted to forensic container).
- **Tines SOAR Enterprise Application Principal ID: 66666666-7777-8888-9999-000000000000**
 - ***Assigned Role:*** Storage Blob Data Contributor (Write-only validation enforcement).

Peak Incident Volumetric Allocations

- **Estimated Peak Alert Concurrency: 150 simultaneous alerts per minute.**
 - ***Sizing Logic:*** Modeled against an active lateral movement storm across a multi-host cluster, generating simultaneous telemetry from Cisco SASE (egress blocks), SentinelOne (credential dump detections), and BeyondTrust (unauthorized terminal access).

Orchestration Pipeline Calibration & Throttling Buffers

- **BeyondTrust PRA Cloud API Edge Threshold: Max 120 calls/minute.**
 - ***Tines Logic:*** To accommodate 150 peak alerts while respecting a 128-call vendor threshold, Tines must route permission degradation actions through an internal execution queue bucket using a 30-second sliding-window delay wrapper for items exceeding index 100.
 - **Cisco SASE Secure Connect API Constraint: Max 5 write requests/second.**
 - ***Tines Logic:*** Tines micro-segmentation commands must enforce an automated rate-limiting buffer block using native HTTP 429 Retry-After response handling to protect integrity control channels.
-